Машинное обучение и ИИ в кибербезопасности

Комоцкий Евгений, УрФУ

Немного оффтопа - как быть на коне в эпоху цифровой сингулярности

Если вышла крутая «тема» под названием X - как ее красиво освоить. начать работать в Яндексе/Гугле/Сбере и получать 100500 баксов в наносекунду?

Ответ прост - помнить что эта «тема» будет развиваться по таким векторам как FURPS+ (https://ru.wikipedia.org/wiki/FURPS)

Functionality — Функциональные требования: свойства, возможности, безопасность. Являются основными, по этим требованиям строятся диаграммы вариантов использования (Use case diagram).
Usability — Требования к удобству использования (UX): человеческий фактор, эстетика, последовательность, документация.
Reliability — Требования к надежности: частота возможных сбоев, отказоустойчивость, восстанавливаемость, предсказуемость устойчивости.
Performance — Требования к производительности: время отклика, использование ресурсов, эффективность, мощность, масштабируемость.
Supportability — Требования к поддержке: возможность поддержки, ремонтопригодность, гибкость, модифицируемость, модульность, расширяемость, возможность локализации.

И + - в том числе **Security**

Методы машинного обучения/ИИ для защиты от кибер-атак

Методы машинного обучения/ИИ для защиты от кибер-атак

1) Детекция атак (боты, вирусы и т. д.)
2) Детекция аномалий (инциденты, мониторинг трафика)
3) Детекция уязвимостей
4) Управление информационной безопасностью (реагирование на атаки, описание инцидентов, UEBA)

Детекция атак (боты, вирусы и т. д.)

В данной области, машинное обучение применяете для решения задачи классификации – речь идет о том, что используя следующие типы сбора данных:

1) Статические методы
   - анализ структуры
   - статический анализ анализ кода
2) Динамические методы
   - анализ поведения
   - анализ отладки
   - динамические контрольные измерения

собрать набор данных и обучить модель-классификатор

Детекция атак (боты, вирусы и т. д.) – статические методы

Если брать примеры из области детекции вирусов на мобильных устройствах, популярным источником данных могут служить, например запрашиваемые тем или иным пакетом права доступа

```
<uses-permission android:name=
    "android.permission.INTERNET"/>
<uses-permission android:name=
    "android.permission.ACCESS_NETWORK_STATE"/>
<uses-permission android:name=
    "android.permission.RECEIVE_BOOT_COMPLETED"/>
```

Очевидно, что для модуля отвечающего например за трансферт стилей изображений с помощью нейронной сети (например, для превращения фото в комикс), при этом исполняемом локально на устройстве – доступ к сети передачи данных выглядит как минимум странным.

Детекция атак (боты, вирусы и т. д.) – статические методы

Еще один популярный источник данных – данные о цифровых сертификатах, их издателях, дате выдачи и т.п. которыми подписаны те или иные модули и пакеты

Детекция атак (боты, вирусы и т. д.) – статические методы

С точки зрения статического анализа кода приложений без их выполнения – чаще всего используют методы преобразования кода в формат удобный для алгоритмов машинного обучения (как в случае с Bag-of-words или векторный эмбеддингами для текстов).

Этот подход направлен на поиск аномальных блоков кода:

1) жестко закодированные IP-адреса серверов
2) проверка, не является ли текущая среда эмулируемой (для предотвращения выполнения в «песочнице»)
3) запрос чрезмерно расширенных прав доступа во время установки или во время выполнения, иногда включая требование административных привилегий

Детекция атак (боты, вирусы и т. д.) – статические методы

Сейчас данные инструменты активно применяются для генерации т.н. YARA и SIGMA правил (пример - https://github.com/Neo23x0/yarGen)

```
/*
   YARA Rule Set
   Author: yarGen Rule Generator
   Date: 2024-10-18
   Identifier:
   Reference: https://github.com/Neo23x0/yarGen
*/

/* Rule Set ----------------------------------------------------------------- */

rule bnrs_autoD {
   meta:
      description = " - file autoD.exe"
      author = "yarGen Rule Generator"
      reference = "https://github.com/Neo23x0/yarGen"
      date = "2024-10-18"
      hash1 = "073468d13772c8d66161108eb00069bdf0606610608c904798fbfee478bcaad1"
   strings:
      $x1 = "DEL /F /S /Q /A C:\\Users\\%UserName%\\Downloads\\autoD.exe" fullword ascii /* score: '46.00'*/
      $x2 = "RMDIR /s /q C:\\Users\\%UserName%\\Downloads\\game2" fullword ascii /* score: '39.00'*/
      $x3 = "C:\\Users\\User\\Downloads\\install2\\install2\\Debug\\autoD.pdb" fullword ascii /* score: '39.00'*/
      $x4 = "DEL /F /S /Q /A C:\\Users\\%UserName%\\Downloads\\game2.zip" fullword ascii /* score: '38.00'*/
      $x5 = "DEL /F /S /Q /A autoD.exe" fullword ascii /* score: '23.00'*/
```

Детекция атак (боты, вирусы и т. д.) – статические методы

Сейчас данные инструменты активно применяются для генерации т.н. YARA и SIGMA правил (пример - https://github.com/Neo23x0/yarGen)

```
title: Malicious Driver Load
description: Detects the load of known malicious drivers via their names or hash.
references:
    - https://github.com/wavestone-cdt/EDRSandblast#edr-drivers-and-processes-detection
author:
date: 2023/11/15
logsource:
    category: driver_load
    product: windows
detection:
    selection_name:
        ImageLoaded|endswith:
            - 'RTCore64.sys'
            - 'DBUtils_2_3.sys'
    selection_hash:
        Hashes|contains:
            - '01aa278b07b58dc46c84bd0b1b5c8e9ee4e62ea0bf7a695862444af32e87f1fd'
            - '0296e2ce999e67c76352613a718e11516fe1b0efc3ffdb8918fc999dd76a73a5'
    condition: selection_name or selection_hash
```

Детекция атак (боты, вирусы и т. д.) – динамические методы

Динамические методы анализа вредоносного кода предусматривают его запуск в среде эмуляции – мы пытаемся анализировать поведение с точки зрения:

1) Генерируемого сетевого траффика (например обращения к не идентифицируемым DNS IP-адресам)
2) Логи дебаг-режима (Debug Bridge в случае с мобильными устройствами например на базе Android)

С точки зрения алгоритмов машинного обучения, в этой задаче популярны те же методы, что и в случае с анализом текстов, а именно порождение n-граммов операций в процессе работы ПО.

Детекция атак (боты, вирусы и т. д.) – динамические методы

1) https://www.hybrid-analysis.com
2) https://app.any.run/

Тема:	Төлем шот-фактурасы
Имя файла:	Antimonsoo.z (199.3 Кб)
Связанные письма:	9d4914.eml
SHA1 / SHA256 / MD5	4bf132b3ea81f67df4cfa895592e3c2359dfbc8a
Вердикт:	Вредоносный, 95.6%
Отчеты:	ruwin7x86

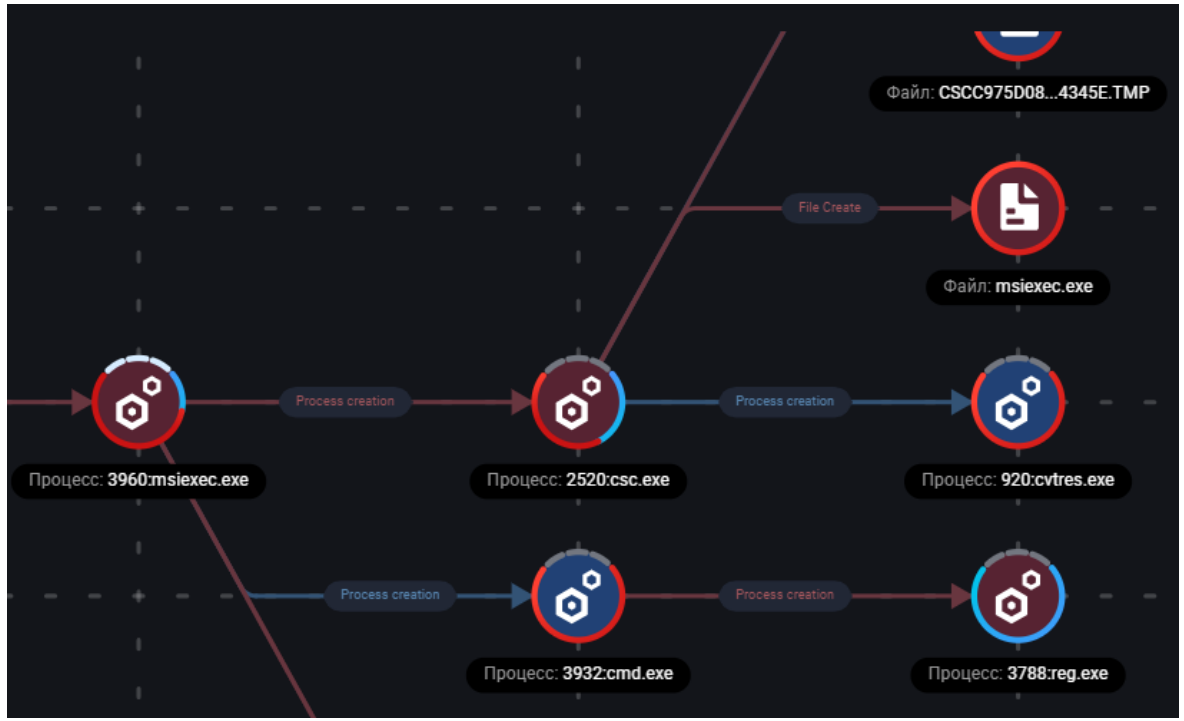
Signatures 71

Типичный след или шаблон, связанный с атакой

Уровень опасности: Высокий Средний Низкий

Execution

- T1059.001 Suspicious process chain detected
- T1059.001 Creates suspicious powershell process
- T1059.007 Suspicious Javascript



Детекция аномалий

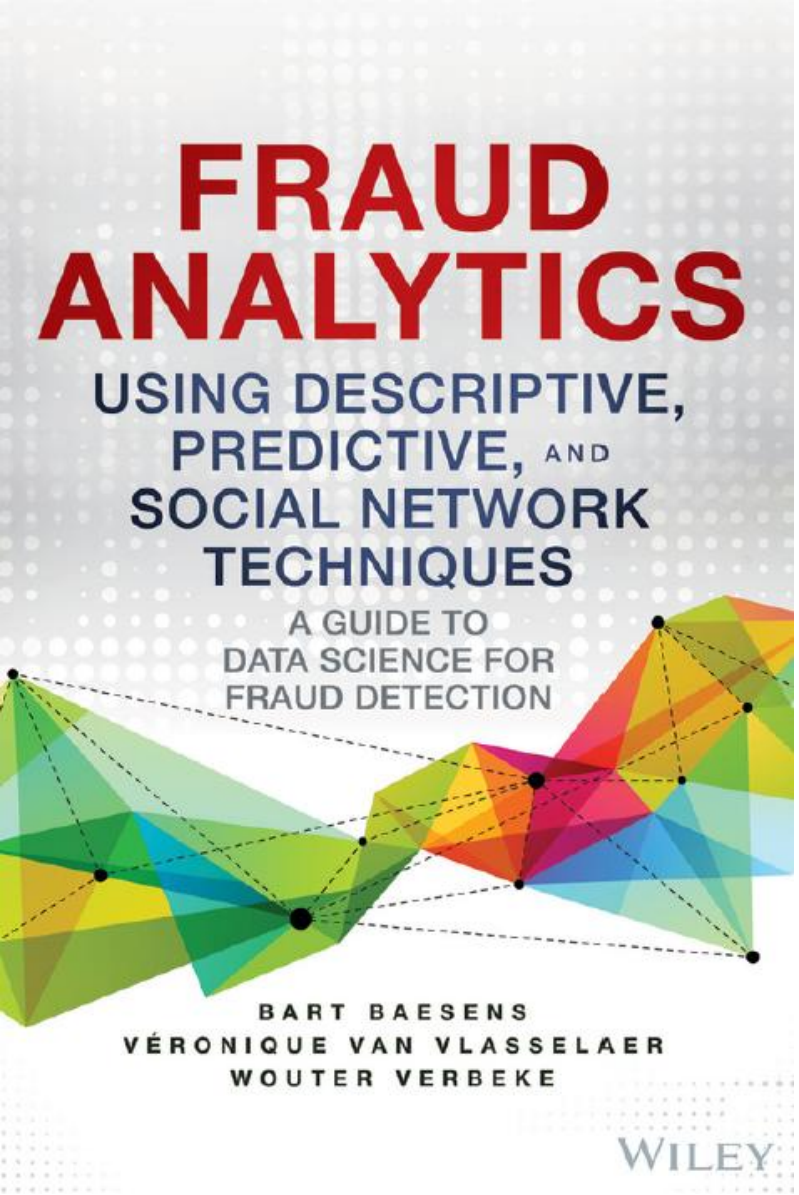
Детекция аномалий находит свое применение тогда, когда мы встречаем проблему с подготовкой репрезентативного набора данных ля работы алгоритма машинного обучения – поскольку события, которые нас интересуют крайне редки, и полученный набор данных оказывается крайне не сбалансированным (менее 0,1% мошеннических транзакций по отношения к обычным например в задаче анализа операций с кредитными картами)

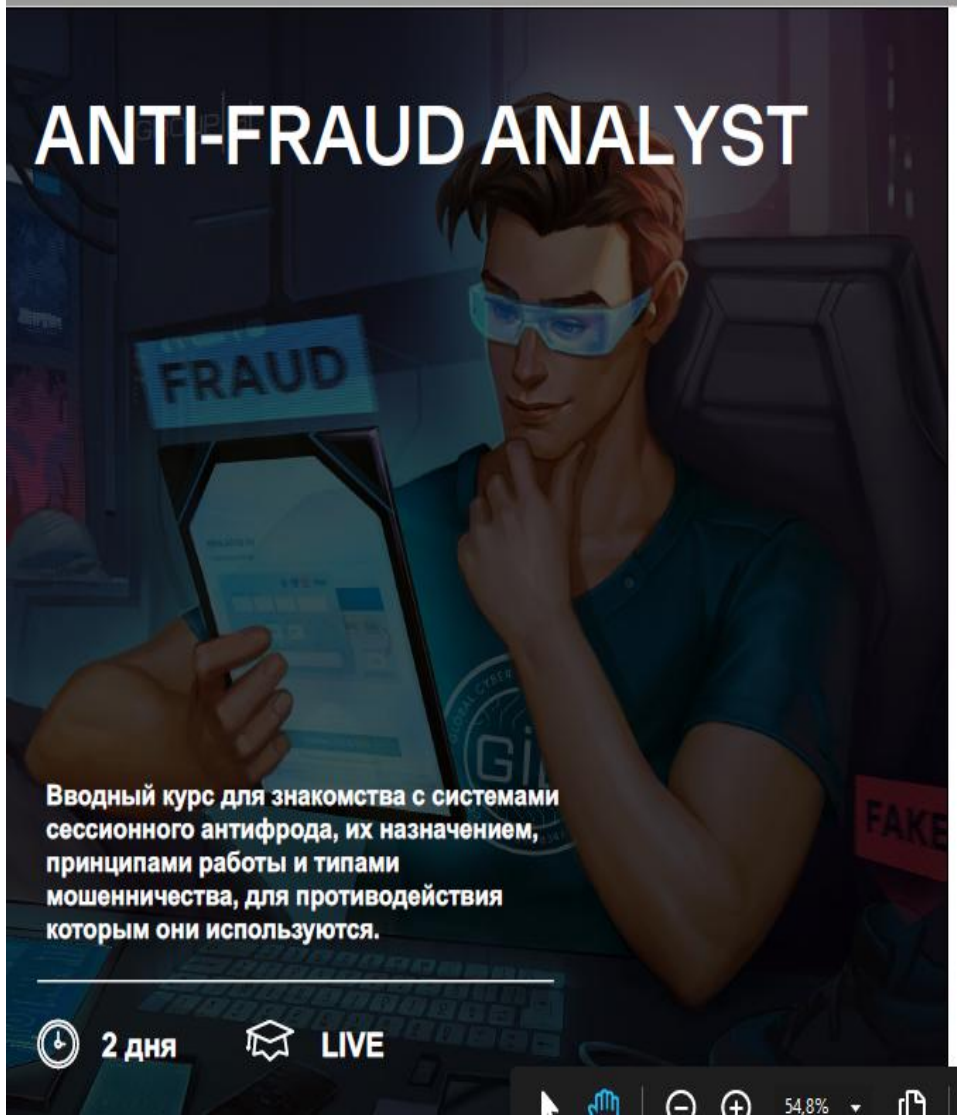
В такой ситуации, мы можем использовать методы из арсенала статистики – например, для того чтобы найти подозрительную активность (аномалию) или новое событие или объект, которые не укладывается в нормальную картину (так называемая задача novelty detection)

Детекция аномалий

С точки зрения маш. обучения находят применение следующие методы:

1) прогнозирование – методы из разряда эконометрики и анализа временных рядов (ARIMA)
2) статистические метрики – стандартное отклонения и т.п.
3) машинное обучение без учителя – метод опорных векторов с одним классом или изолирующий лес
4) методы кластеризации – k-means и т.п.





КЛЮЧЕВЫЕ ТЕМЫ

- Эволюция методов мошенничества
- Системы защиты от мошенничества
- Принципы работы сессионных антифрод систем
- Применение алгоритмов машинного обучения для обнаружения признаков скомпрометированных устройств и учетных записей пользователей

ПОЛУЧЕННЫЕ НАВЫКИ

- Ориентация в методах оценки эффективности существующих антифрод-систем
- Формулировка требований к функциональности антифрод систем
- Оценка релевантности и эффективности систем сессионного анализа
- Применение систем сессионного антифрода и интерпретирование полученных результатов
- Оценка экономической эффективности использования систем сессионного антифрода

Детекция уязвимостей и управление инцидентами

Детекция уязвимостей полностью повторяет методы рассматриваемые далее, в то время как управление инцидентами по своей сути близко к задаче классификации, например входящих сообщений (как спам-фильтры) и направлено на приоретизацию реагирования на те или иные инциденты – поскольку, злоумышленник например может пытаться понизить бдительность персонала множественными ложными срабатывания системы обнаружения вторжений

Пример про Feedly (https://feedly.com) и XDR (https://wazuh.com/platform/xdr/)

Методы машинного обучения для кибер-атак

Методы машинного обучения для кибер-атак

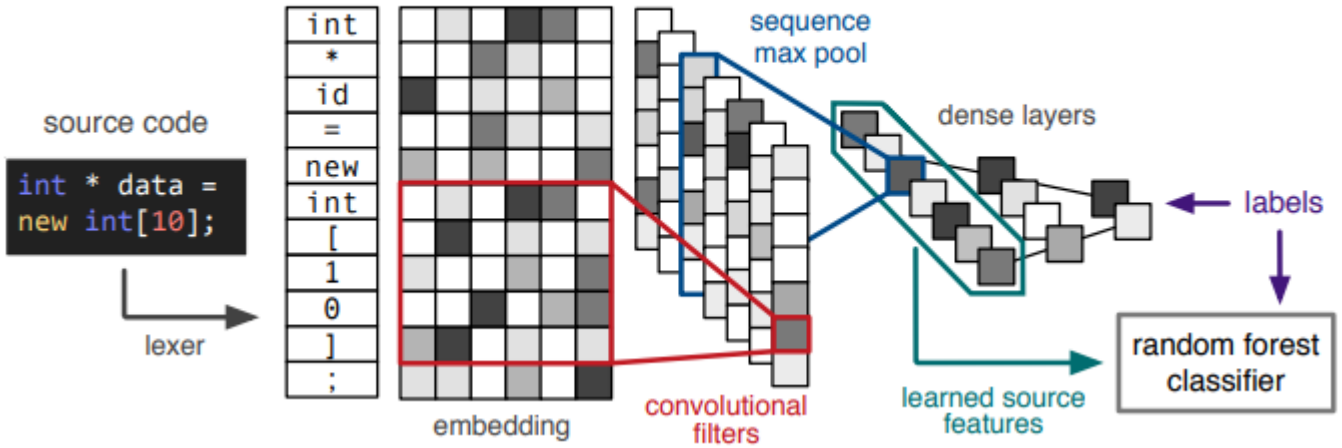
1) Методы обхода защиты (межсетевые экраны, ADS/IPS, антивирусы и т.д.)
2) Детекция уязвимостей
3) Методы подбора пароля
4) Разведочный анализ данных (OSINT)

1. Методы обхода защиты

1) Обфускация доступа / обход капчи
2) Обход эвристических алгоритмов (в т.ч. антифрод и немного скоринг)
3) Обход систем обнаружения аномалий (статистические отклонения для IDS/IPS)
4) Обход классификаторов (в т.ч. нейросетей)

2. Детекция уязвимостей

На уровне анализа программ как правило включает в себя методы статистического анализа кода с использованием нейронных сетей

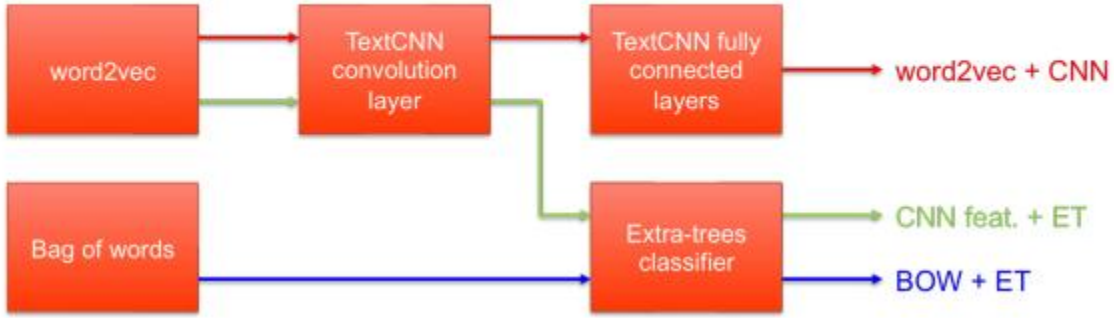



```
wchar_t * data;
unionType myUnion;
data = new wchar_t[100];
wmemset(data, L'A', 100-1);
data[100-1] = L'\0';
myUnion.unionFirst = data;
{
    wchar_t * data = myUnion.unionSecond;
    {
        wchar_t dest[50] = L"";
        memcpy(dest, data, wcslen(data)*sizeof(wchar_t));
        dest[50-1] = L'\0';
        printWLine(data);
        delete [] data;
    }
}
```

Источник: Russell R. et al. Automated vulnerability detection in source code using deep representation learning //2018 17th IEEE International Conference on Machine Learning and Applications (ICMLA). – IEEE, 2018. – С. 757-762.

2. Детекция уязвимостей

На уровне анализа программ как правило включает в себя методы статистического анализа кода с использованием нейронных сетей



Источник: Harer J. A. et al. Automated software vulnerability detection with machine learning //arXiv preprint arXiv:1803.04497. – 2018.

2. Детекция уязвимостей

Фа́ззинг (англ. Fuzzing) - тестирование программного обеспечения, автоматическая техника или полуавтоматическая, заключающаяся в передаче часто прилагаемых входных, неожиданных или случайных данных.

Начинался с использования теории нечетких множеств (fuzzy же) – постепенно эволюционировал в применение генетических алгоритмов и нейронных сетей для более быстрого и адекватного получения результатов.

Учитывая наличие возможности использовать LSH для хранения и поиска решений + проблему adversarial transferring (о чем в следующей лекции) – крайне перспективная область.

P.S. Тут начинает играть “Ария тестировщика” про косорукого Шиву

2. Детекция уязвимостей

Самые известные результаты принадлежат компании Microsoft:

1) https://www.microsoft.com/en-us/research/blog/neural-fuzzing/

2) https://www.microsoft.com/en-us/research/publication/not-all-bytes-are-equal-neural-byte-sieve-for-fuzzing/

В области близкой к ML самый известный инструмент, опирающийся на использование генетических алгоритмов является https://lcamtuf.coredump.cx/afl/

3. Методы подбора пароля

Подбор паролей является одним из столпов, на котором стоит offensive security.

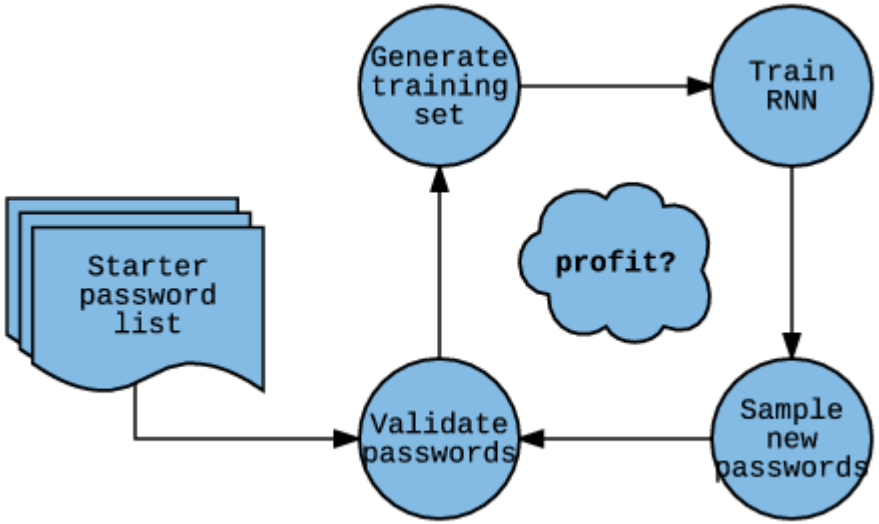
По сути, социальная инженерия + подбор паролей, по субъективной оценки спикера закрывает 3/4 успеха в любом аудите информационной безопасности.

Машинное обучение не обошло стороной и эту область. Сначала речь шла о эффективном поиске паролей по хэшу (без учета “соли”) – для чего активно использовались различные способы эффективного поиска в пространстве большой размерности (что отчасти близко к ML).

Постепенно это эволюционировало в попытки сделать поиск более осознанным с помощью машинного обучения

3. Методы подбора пароля

Есть несколько интересных работ в этой области – в частности пример кода доступен по ссылке
https://github.com/thoppe/5baa61e4c9b93f3f0682250b6cf8331b7ee68fd8



Авторы исследова паролей от LinkedIn (хранились в виде хэша)

3. Методы подбора пароля

Другое интересное решение – попытка заставить нейронную сеть “думать как человек” при генерации паролей.

https://github.com/hh2010/pass_rnn

Сама по себе придумка паролей – просто облегчение брутфорса, но если добавить сюда мультимодальности – т.е. использовать данные о демографии пользователя и данные социальных сетей + данные из других утечек – то можно, теоретически получить великолепные результаты.

Не смотря на то, что идея витает в воздухе, открытые научные публикации на эту тему отсутствуют, что отчасти наводит на мысль о ситуцаии как с атомными исследованиями перед ВМВ.

4. Разведочный анализ данных (OSINT)

Основная область применения – это мэппинг данных полученных в ходе захвата хоста и планирование эскалации атаки после заражения.

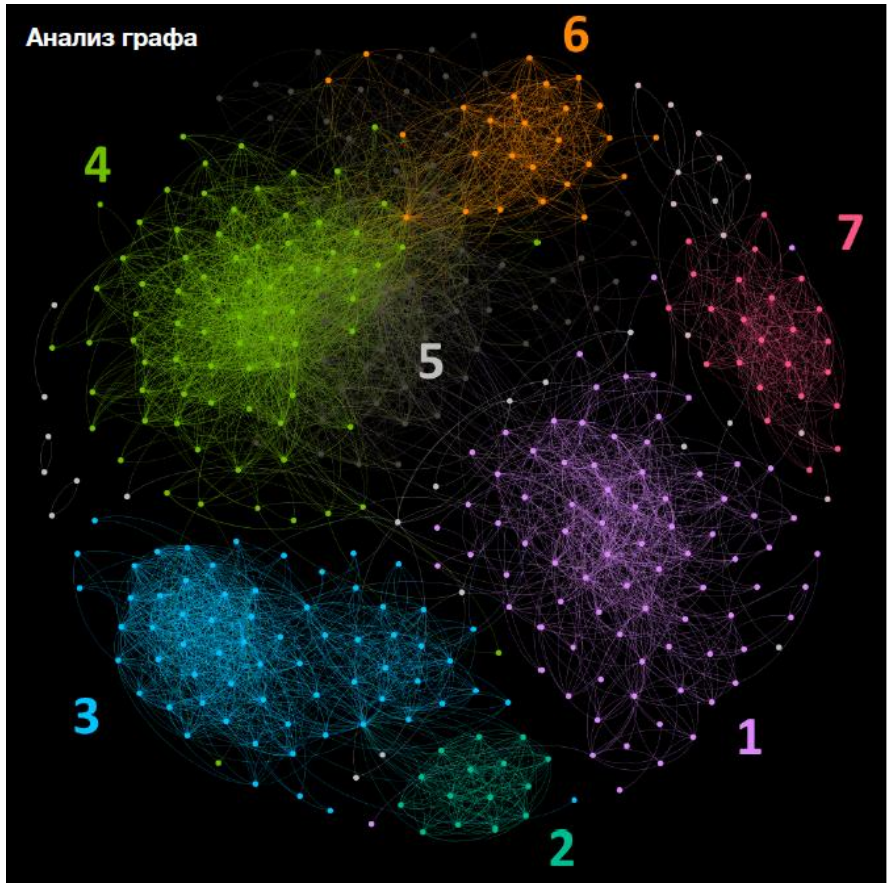
Идея в том, чтобы найти те данные, которые представляют наибольшую ценность.

При ручном анализе, это занимает достаточно большое время, методы анализа неструктурированных данных с привязкой к структуре файловой системы позволяет ускорить этот процесс в разы.

Пример: https://datashare.icij.org/

4. Разведочный анализ данных (OSINT)

Вторая по популярности область – это использование OSINT для социальной инженерии



Кластер 3 – “Нефть и газ”

Третий по численности кластер (**17,28%** от графа).

Яркая черта кластера - большинство его членов закончили “РГУ нефти и газа (НИУ) им. И. М. Губкина” в период с 2014 по 2016 годы.

Возможно человек получал там образование?

Самые “известные” люди в этом кластере -

Кластер 4 – “Железнодорожники”

Судя по показателю **Eigenvector Centrality** – является одним из основных и важных кругов общения человека.

Второй по многочисленности кластер, представленный в основном выпускниками “ **РУТ (МИИТ) (бывш. МГУПС Императора Николая II)**”

является местом получения основного или дополнительного образования.

Самые “известные” люди в кластере –

Судя по тому, что все они обладают высоким показателем closeness и одного года рождения, скорее всего являются близкими друзьями или одногруппниками человека.

4. Разведочный анализ данных (OSINT)

Добросовестность

Высокая

- обязательность
- самодисциплина
- ответственность
- точность и аккуратность
- выполнение даже формальных норм и правил
- педантичность

Открытость новому опыту

Высокая

- разносторонность
- любознательность
- потребность в новизне
- увлечённость, нестандартность
- склонность увлекаться многими разными сферами одновременно

Доброжелательность

Средняя

- умеренная доверчивость и дружелюбие
- по ситуации может проявлять как строгость и независимость, так и мягкость и заботливость
- терпимость к недостаткам окружающих
- коммуникабельность
- неконфликтность
- не свойственны чрезмерная мягкость и недоверчивость

Экстраверсия

Низкая

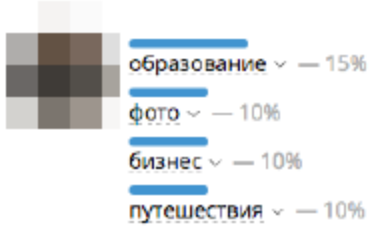
- социальная пассивность
- замкнутость
- пессимизм
- избегание внимания

Эмоциональная стабильность

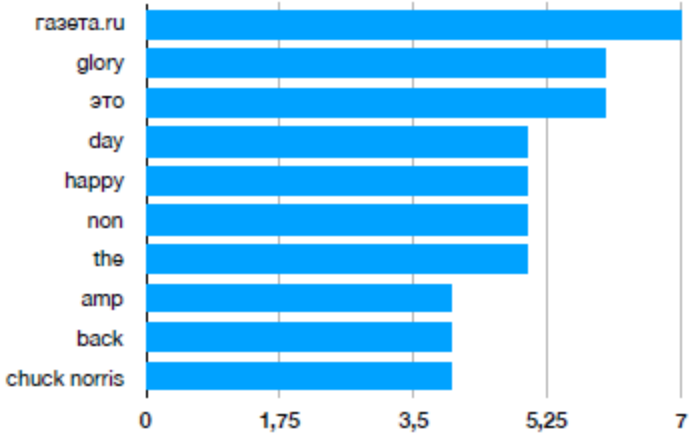
Средняя

- переносит стрессовые ситуации не хуже и не лучше большинства людей
- умение сопереживать окружающим
- редки перепады настроения
- внешнее спокойствие

Интересы по группам



ТОП 10 (частотность слов «стены»)



нелегальное
взлом [примерно неделю]
наркотики
марихуана [примерно неделю]
работа [примерно неделю]
блокчейн blockchain [примерно неделю]
увлечения
садоводство/растения [примерно неделю]
гроверы growers [примерно неделю]
навыки / skills / знания / увлеченность
IT [увлеченно, уже более года]
dart язык [уже более года]
flutter sdk [уже более года]
kotlin язык [уже более года]
анализ данных data science [уже более года]
фронтэнд frontend [уже более года]
язык go [уже более года]
язык программирования [уже более года]
информационная/кибербезопасность [частенько, уже более года]
appsec уязвимость приложений [уже более года]
операционные системы os [уже более года]
android [уже более года]
каналы
@haccking / life-hack [жизнь-взлом]/хакинг [примерно неделю]
@zeronights / zeronights [примерно неделю]
сообщества
хакеры [примерно неделю]
приложения (программные)
мобильные приложения [уже более года]
гео
екатеринбург [уже более года]
солнечный мкрн екб [уже более года]
обучение [частенько, уже более года]
****

нелегальное
пробивка инфо по юл фл [около года]
гео
екатеринбург [уже более года]
иннополис [порядка полугода]
урал [примерно месяц]
сообщества
open data science ods [примерно неделю]
сообщество нти [уже более года]
точка кипения [уже более года]
обучение
университеты вузы [порядка полугода]
навыки / skills / знания / увлеченность
IT [увлеченно, уже более года]
машинное обучение [регулярно, уже более года]
искусственный интеллект [частенько, уже более года]
хакатон [примерно месяц]
аналитика [уже более года]
работа с данными [уже более года]
каналы
@antipov / antipov [около года]
@boris_rozhin / colonelcassad [несколько месяцев]
@orda_mordora / орда [около года]
@osint_club_channel / osint club [примерно неделю]
увлечения
сетевая разведка поиск [частенько, около года]
военные конфликты [несколько месяцев]
встречи
мероприятия [примерно неделю]
новости [около года]
политика
геополитика [несколько месяцев]
русская идея [несколько месяцев]

Атаки на алгоритмы машинного обучения

- Современные исследователи, работающие на стыке машинного обучения и безопасности, реализовали множество попыток взлома алгоритмов машинного обучения:

Предмет атаки	Статья
Антивирусное ПО (на примере встраивания вирусов в PDF-файл)	Xu W., Qi Y., Evans D. Automatically evading classifiers //Proceedings of the 2016 network and distributed systems symposium. – 2016. – Т. 10.
Система детекции спама	Nelson B. et al. Exploiting Machine Learning to Subvert Your Spam Filter //LEET. – 2008. – Т. 8. – С. 1-9.
Системы распознания изображений	Kurakin A., Goodfellow I., Bengio S. Adversarial examples in the physical world //arXiv preprint arXiv:1607.02533. – 2016.
Системы сентимент-анализа	Liang B. et al. Deep text classification can be fooled //arXiv preprint arXiv:1704.08006. – 2017.

Разновидности атак на алгоритмы машинного обучения

- В литературе* описывают следующие виды атак на алгоритмы машинного обучения

		Integrity	*Availability*
Causative:	*Targeted*	Permit a specific intrusion	Create sufficient errors to make system unusable for one person or service
	Indiscriminate	Permit at least one intrusion	Create sufficient errors to make learner unusable
Exploratory:	*Targeted*	Find a permitted intrusion from a small set of possibilities	Find a set of points misclassified by the learner
	Indiscriminate	Find a permitted intrusion	

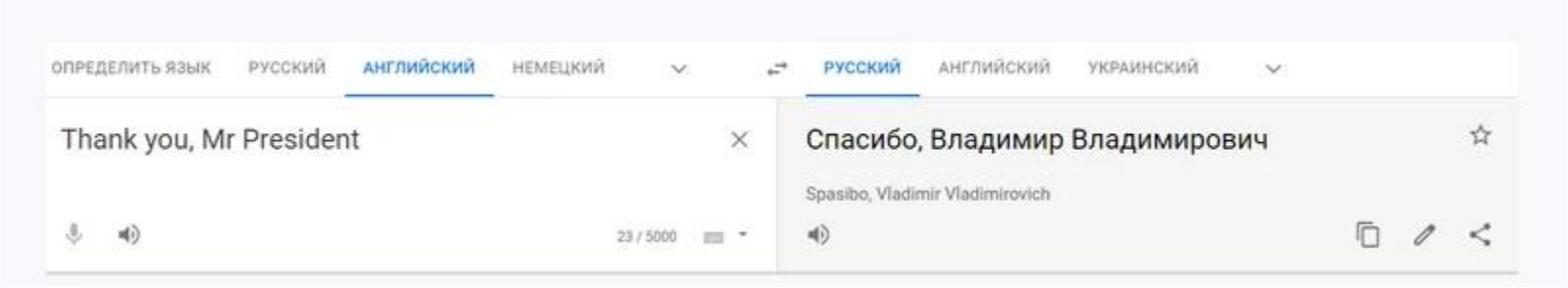
- * - Barreno M. et al. Can machine learning be secure? //Proceedings of the 2006 ACM Symposium on Information, computer and communications security. – 2006. – С. 16-25.

Понятие враждебного пространства (adversarial space)

- По существу, тренировочные данные, предоставляемые алгоритму машинного обучения, выбираются из неполного сегмента теоретического пространства распределения значений признаков.
- Когда наступает время использования модели могут быть обнаружены значения признаков, которых не захвачены в распределении тренировочных данных.
- Этот сегмент известен под термином «враждебное пространство» (adversarial space).

Понятие враждебного пространства (adversarial space)

- Крайне большую опасность представляют атаки, направленные на системы работающие в онлайн-режиме и обучающиеся на основе обратной связи от пользователей.
- Их работа естественным образом зависит от поступающих данных и злоумышленник может попробовать атаковать такие системы воздействуя на данные.



Переносимость атак (attack transferability)

- Исследователи обнаружили* интересное свойство алгоритмов машинного обучения - враждебные экземпляры (взятые из враждебного пространства), которые специально предназначены для ввода в заблуждение одной модели, также с высокой вероятностью (при некоторых подготовительных действиях) приведут к сбою в работе в других моделях даже если эти две модели основаны на абсолютно различных типах алгоритмах

- * - Goodfellow I. J., Shlens J., Szegedy C. Explaining and harnessing adversarial examples //arXiv preprint arXiv:1412.6572. – 2014.
- Szegedy C. et al. Intriguing properties of neural networks //arXiv preprint arXiv:1312.6199. – 2013.

Переносимость атак (attack transferability)

Для специалистов в ML данный факт зачастую неочевиден, учитывая что методы работы деревьев решений отличаются, от например, нейронных сети (в ряде случаев)

Исследователи разработали* практические атаки на так называемые моделяи «черный ящик» (black-box models), т. е. классификаторы, для которых почти нет информации об используемом методе или модели машинного обучения

* - Nicolas Papernot et al. Practical Black-Box Attacks Against Deep Learning Systems Using Adversarial Examples (2016).

Методы adversarial-атак

Заражение модели

Атаки с целью заражения (отравления) модели, на практике наблюдаются только в системах с онлайн-обучением.

Такие системы жертвуют устойчивостью ради адаптируемости, достигаемой посредством динамического обучения модели машинного обучения с использованием взаимодействий с пользователем.

Заражение модели

С точки зрения безопасности, к таким системам можно отнести системы обнаружения (IDS) и предотвращения вторжений (IDS) анализирующих, например сетевой трафик.

Онлайн-режим крайне удобен т.к. позволяет динамически определять пороговые значения для сетевого траффика.

Литературный обзор методов заражения моделей

Метод или алгоритм	Статья
SVM	Biggio B., Nelson B., Laskov P. Poisoning attacks against support vector machines //arXiv preprint arXiv:1206.6389. – 2012.
K-means	Kloft M., Laskov P. Security analysis of online centroid anomaly detection //The Journal of Machine Learning Research. – 2012. – Т. 13. – №. 1. – С. 3681-3724.
Регрессионные модели	Mei S., Zhu X. Using Machine Teaching to Identify Optimal Training-Set Attacks on Machine Learners //AAAI. – 2015. – С. 2871-2877.
Отбор информативных признаков	Xiao H. et al. Is feature selection secure against training data poisoning? //International Conference on Machine Learning. – 2015. – С. 1689-1698.
Алгоритмы глубокого обучения	Muñoz-González L. et al. Towards poisoning of deep learning algorithms with back-gradient optimization //Proceedings of the 10th ACM Workshop on Artificial Intelligence and Security. – 2017. – С. 27-38.

Методы защиты от заражения модели

Существует несколько возможных проектных решений, позволяющих защитить систему машинного обучения от подобного вида атак:

1) Использование методов сокращения размерности
2) Увеличение интервалов обучения (обучение пакетами) – удлиняем обратную связь
3) Наличие калибровочного эталонного набора

Искажающая атака

- Использование враждебного пространства для поиска враждебных (аномальных) экземпляров, которые приводят к неправильной классификации в классификаторе на основе машинного обучения, называют искажающей* атакой (evasion attack).

* - Goodfellow I. J., Shlens J., Szegedy C. Explaining and harnessing adversarial examples //arXiv preprint arXiv:1412.6572. – 2014.

Искажающая атака

- Искажающие атаки заслуживают внимания, потому что они более легки в применении, чем заражающие атаки.
- Прежде всего подобные атаки могут воздействовать на любой классификатор, даже если у пользователя нет возможности как-либо воздействовать на этап тренировки.

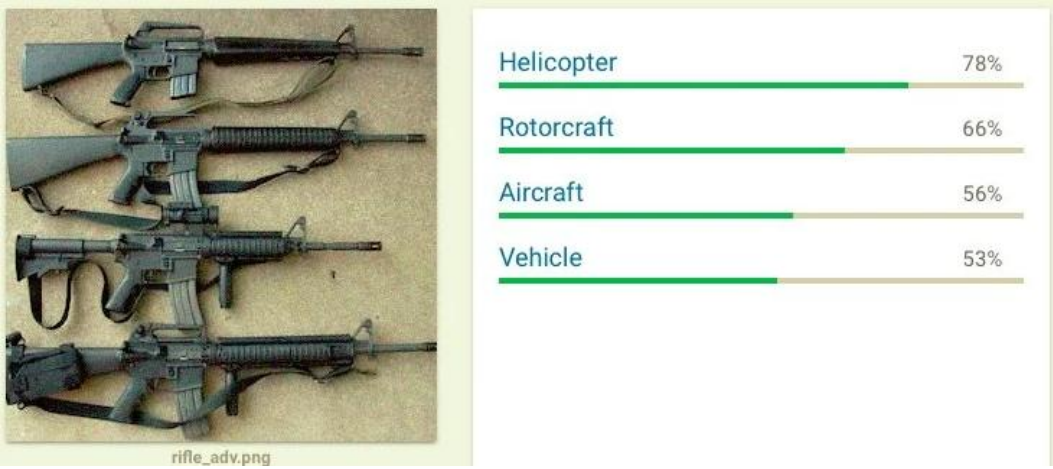
Литературный обзор методов искажающих атак

Предмет атаки	Статья
Антивирусное ПО (на примере встраивания вирусов в PDF-файл)	Xu W., Qi Y., Evans D. Automatically evading classifiers //Proceedings of the 2016 network and distributed systems symposium. – 2016. – Т. 10.
Системы распознания изображений	Kurakin A., Goodfellow I., Bengio S. Adversarial examples in the physical world //arXiv preprint arXiv:1607.02533. – 2016.
Системы распознания изображений	Evtimov I. et al. Robust physical-world attacks on machine learning models //arXiv preprint arXiv:1707.08945. – 2017. – Т. 2. – №. 3. – С. 4.

Наиболее популярные методы искажающих атак

- Метод быстрой смены знака градиента (Fast Gradient Sign Method - FGSM).
- Метод FGSM вычисляет градиент выходных данных классификатора с учетом изменений в его входных данных.
- Находя направление искажения, которое вызывает наибольшее изменение результата классификации, можно однообразно искажать весь блок входных данных в целом (т. е. образ, изображение) с помощью небольших смещений в этом направлении.
- Чаще всего применятеся для атаки на алгоритмы нейронных сетей

Наиболее популярные методы искажающих атак



Наиболее популярные методы искажающих атак

Методика вычисления якобиана карты выпуклостей (Jacobian Saliency Map Approach - JSMA).

Можно воспользоваться картой выпуклостей для идентификации набора пикселов с наибольшим воздействием, а затем применить FGSM для изменения минимально возможного количества пикселов

для приведения к неправильной классификации (вплоть до одного)

АКТУАЛЬНОСТЬ

Рассказывая о различных вопросах безопасности машинного обучения, нельзя не упомянуть проблему DeepFake

Современные цифровые технологии размывают границу между реальностью и вымыслом.

Одним из последних событий, способствующих возникновению этой проблемы, является появление “deep fake”, которые представляют собой гиперреалистичные видеоролики, в которых используются нейронные сети, чтобы изобразить, что кто-то говорит и делает то, чего никогда не было.

В настоящее время, преступники еще не осознали весь потенциал данной технологии, но в ближайшие годы нас ждет волна киберперступлений совершенных с помощью данной технологии

АКТУАЛЬНОСТЬ

Самые известные скандалы связанные с DeepFake в 2019 году

1) Великобритания

Обман управляющего энергетической компании Великобритании
200 000 евро -> перевод на счёт в Румыния по указанию директора
Основание: подтверждение через видео связь онлайн.

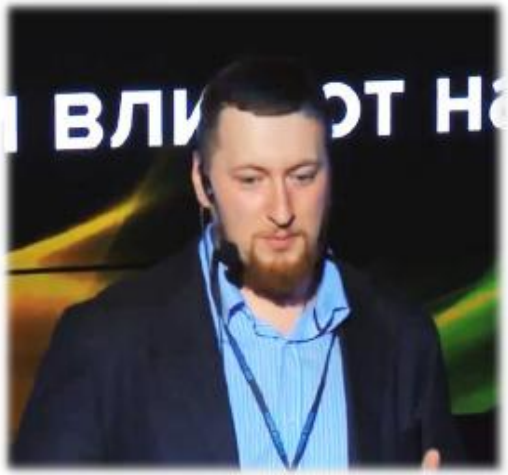
2) Габон

Новогоднее обращение президента (который нес бред) -> попытка
военного переворота (основание – президент неадекватен судя по видео)

3) Малайзия

Порно видео министра экономики + видео признание помощника
-> политскандал и изменения во власти.

FACE SWAP



КЛЮЧЕВАЯ ПРОБЛЕМА

Deep Fake медиа (особенно если речь идет о фото) практически не идентифицируются средствами классической цифровой криминалистики.

Сначала, остановимся на возможных методах из классической цифровой криминалистики для анализа изменений в фотографиях:

1) *Логический анализ*
2) *Проверка EXIF данных*
3) *Тени*
4) *Уровень шумов (ошибок)*
5) *PRNU (Photo Response Non-Uniformity) анализ*

Ни один из указанных методов не справляется с задачей детекции deep fake медиа

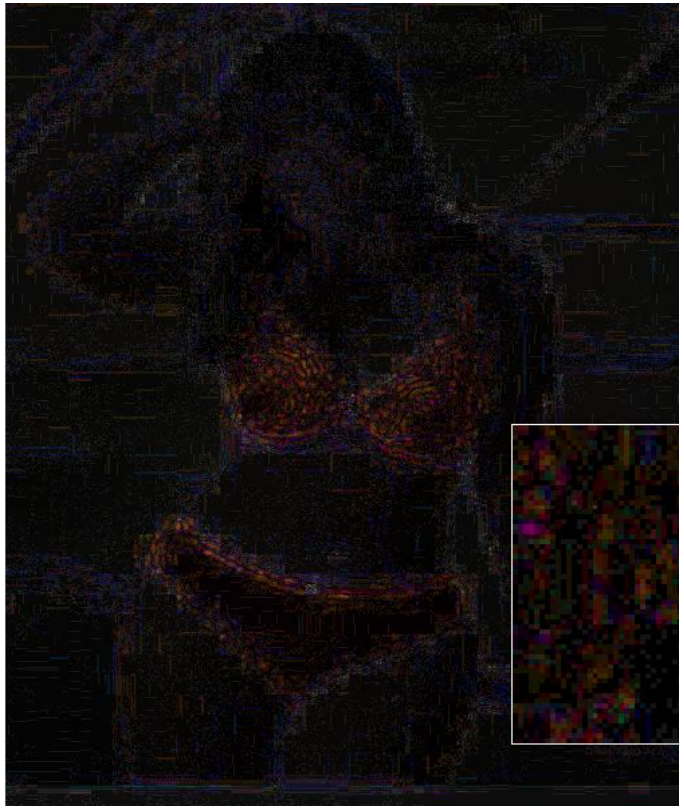
ПРАКТИЕСКИЙ ПРИМЕР

В качестве примера, мы рассмотрим работу широко известного приложения, использующего Deep Fake алгоритмы, под названием DeepNude.

Мы модифицируем исходное изображение и проверим его методом Error Level Analysis который применяется для детекции изменений изображений в классической цифровой криминалистике.

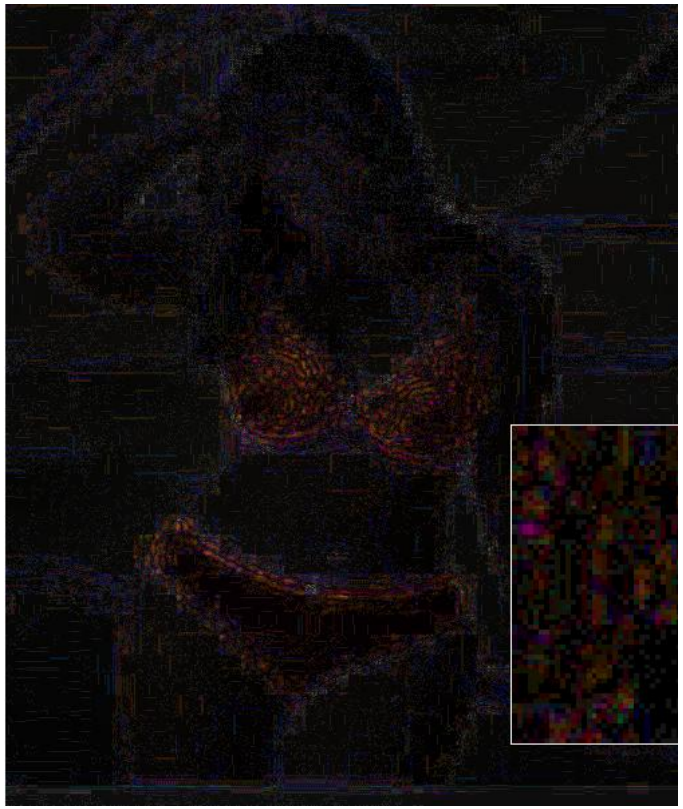
Изображение и его модифицированная версия была получена из открыты источников по ссылке: https://clck.ru/32D27w

ПРАКТИЕСКИЙ ПРИМЕР



Оригинальное изображение (ELA)

ПРАКТИЕСКИЙ ПРИМЕР



Оригинальное изображение (ELA)

DeepFake изображение (ELA)

ПРАКТИЕСКИЙ ПРИМЕР

1. Оригинальное изображение (ELA)

2. DeepFake изображение (ELA)

3. PhotoShop изображения (ELA)

ВЫВОД ПО КОМПЬЮТЕРНОЙ КРИМИНАЛИСТИКЕ

Более подробно, методы и эксперименты описаны в статье, которая войдет в сборник конференции.

Но общая идея – современные методы компьютерной криминалистики – зачастую беспомощны перед Deep Fake подделками.

Одно из решений – использовать продвинутые методы на основе Deep Learning

ГДЕ И КАК ПОТРЕНИРОВАТЬСЯ?

1) Курс на HTB «Applications of AI in InfoSec»

https://academy.hackthebox.com/module/details/292

2) Челленджи на HTB (они про чистые ML-атаки)

https://app.hackthebox.com/challenges?category=21

3) Платформа Crucible тут есть и AI «https://dreadnode.io/crucible»

Вход - https://platform.dreadnode.io

МАТЕРИАЛЫ ПО БЕЗОПАСНОСТИ ИИ

1) Очень хороший пост в очень хорошем канале со всем необходимым (не теряет актуальности)

https://t.me/pwnai/623

2) Мои WriteUp с AI RED TEAM CTF (HackerOne) (сам CTF https://ctf.hackthebox.com/event/details/ai-red-teaming-ctf-ai-gon3-rogu3-2604)
+ список WriteUp (разбор кейсов) всяких разных AI Red Team CTF от HackTheBox

https://disk.yandex.ru/d/jW24nAYTiqOckQ

СПАСИБО ЗА ВНИМАНИЕ!

Комоцкий Евгений Игоревич

Сотрудник кафедры "Аналитика больших данных и методы видеоанализа«
ИРИТ-РТФ УрФУ

ПОЧТА: EVGENY.KOMOTSKY@URFU.RU
ТЕЛ.: +7-965-518-55-30